

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

Proyecto	Control DICA-MX — Plataforma de Gestión Documental
Organización	DICA México / TKS México
Elaborado por	Rodrigo Fuentes Espinoza, Coordinador de Sistemas
Versión	1.0
Clasificación	Confidencial — Uso interno
Norma de ref.	ISO/IEC 27001:2022 — Annex A (A.5.9, A.5.31, A.5.32)

Propósito del documento: Este documento describe la arquitectura técnica del sistema Control DICA-MX, una plataforma centralizada para la carga, custodia y trazabilidad de documentos de entidades externas. Define los componentes del sistema, flujos de datos, modelo de seguridad y estrategia de implementación por fases.

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

SECCIÓN 1

Resumen Ejecutivo

Control DICA-MX es una plataforma web multi-entidad diseñada para la recepción, custodia y trazabilidad de documentos provenientes de clientes externos. El sistema garantiza la integridad de los archivos mediante verificación de hash SHA-256, implementa un flujo de autorización para cualquier solicitud de eliminación, y mantiene un registro de auditoría inmutable alineado con los requisitos de la norma ISO/IEC 27001:2022.

Características principales

Característica	Descripción	Norma relacionada
Autenticación por entidad	Cada cliente accede solo a sus documentos mediante RLS en base de datos	A.5.15, A.8.2
Inmutabilidad de archivos	Object Lock WORM en almacenamiento — físicamente imposible borrar sin autorización	A.8.10
Flujo de autorización	Solicitud → Revisión admin → Aprobación/Rechazo → Ejecución con log	A.5.3
Audit Log inmutable	Registro append-only con timestamp, usuario, IP y hash del recurso	A.8.15
Verificación de integridad	Hash SHA-256 calculado al subir y verificado periódicamente	A.8.11
Aislamiento multi-entidad	Row Level Security garantiza segregación total entre entidades	A.5.9

SECCIÓN 2

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

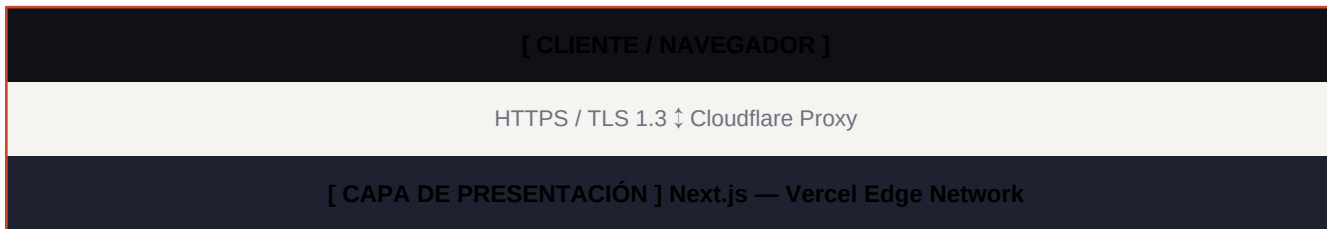
Arquitectura General del Sistema

Stack tecnológico

Capa	Tecnología	Rol	Hosting (Fase 1)
Frontend	Next.js 14 + React	Interfaz web — portal cliente y panel admin	Vercel
Autenticación	Supabase Auth	JWT, sesiones, gestión de usuarios por entidad	Supabase Cloud
Base de datos	PostgreSQL (Supabase)	Metadatos, estados, solicitudes, audit log	Supabase Cloud
Almacenamiento	Supabase Storage / MinIO	Archivos con Object Lock WORM (Fase 2)	Supabase → NAS
CDN / Proxy	Cloudflare	SSL, protección DDoS, DNS, subdominios	Cloudflare Free
DNS / Dominio	Dominio existente + Cloudflare NS	Gestión DNS con subdominios por servicio	Hostinger + CF

Diagrama de capas

El sistema se organiza en cuatro capas principales, cada una con responsabilidades bien definidas y separadas para facilitar el mantenimiento, la auditoría y la migración futura hacia infraestructura self-hosted.



CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

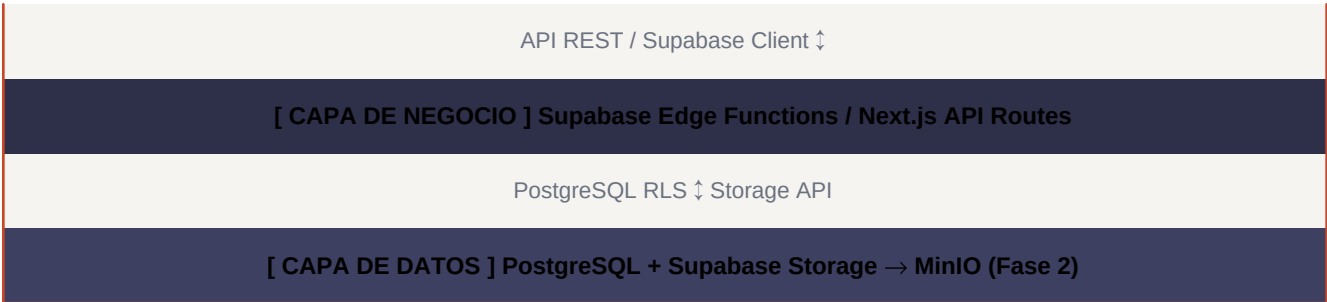


Figura 1 — Diagrama de capas del sistema

SECCIÓN 3

Modelo de Datos

La base de datos en PostgreSQL utiliza Row Level Security (RLS) para aislar los datos de cada entidad. Ninguna consulta del cliente puede acceder a registros de otra entidad, ya que las políticas se aplican a nivel del motor de base de datos, no en la capa de aplicación.

Esquema principal

Tabla	Campos clave	Descripción
entidades	id, nombre, activo, created_at	Registro de clientes/entidades del sistema
usuarios	id, entidad_id, rol, email, created_at	Usuarios por entidad con rol asignado
archivos	id, entidad_id, subido_por, nombre, ruta_storage, hash_sha256, estado, created_at	Metadatos de cada archivo. Estado: activo pendiente_eliminacion eliminado

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

Tabla	Campos clave	Descripción
solicitudes Eliminación	id, archivo_id, solicitado_por, motivo, estado, revisado_por, revisado_at, created_at	Flujo de autorización de eliminación. Estado: pendiente aprobado rechazado
audit_log	id, entidad_id, usuario_id, accion, recurso_id, detalle_json, ip, created_at	Registro inmutable. Solo permite INSERT. Sin UPDATE ni DELETE por política RLS

Políticas RLS — Audit Log

La tabla audit_log es append-only. Las políticas de Supabase eliminan los privilegios de UPDATE y DELETE para todos los roles, incluido el administrador de la aplicación. Solo el rol de servicio (service_role) puede leer la tabla completa para generación de reportes.

```
-- Solo INSERT permitido para usuarios autenticados CREATE POLICY audit_insert ON audit_log
FOR INSERT TO authenticated WITH CHECK (true); -- Solo lectura para service_role (reportes)
CREATE POLICY audit_select ON audit_log FOR SELECT TO service_role USING (true);
```

SECCIÓN 4

Flujos del Sistema

4.1 Flujo de subida de archivo

#	Actor	Acción	Sistema
1	Cliente	Selecciona archivo en el portal	—
2	Frontend	Calcula hash SHA-256 en cliente	Web Crypto API
3	Backend	Valida sesión JWT y entidad_id	Supabase Auth
4	Storage	Sube archivo con Object Lock activo	Supabase Storage / MinIO

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

#	Actor	Acción	Sistema
5	BD	Inserta registro en tabla archivos con hash y estado='activo'	PostgreSQL
6	BD	Inserta evento UPLOAD en audit_log con IP y timestamp	PostgreSQL
7	Cliente	Recibe confirmación con hash verificado	Frontend

4.2 Flujo de solicitud y autorización de eliminación

#	Actor	Acción	Estado
1	Cliente	Solicita eliminación con motivo desde el portal	pendiente
2	Sistema	Crea registro en solicitudes_eliminacion	pendiente
3	Sistema	Registra REQUEST_DELETE en audit_log	—
4	Admin	Recibe notificación en dashboard	—
5a	Admin	APRUEBA: libera Object Lock en MinIO / Storage	aprobado
5b	Admin	RECHAZA: archivo permanece intacto	rechazado
6	Sistema	Actualiza estado del archivo y solicitud en BD	eliminado / activo
7	Sistema	Registra APPROVE_DELETE o REJECT_DELETE en audit_log con admin responsable	—

SECCIÓN 5

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

Modelo de Roles y Permisos

Acción	Cliente	Admin	Super Admin
Ver sus propios archivos	✓	✓	✓
Ver archivos de todas las entidades	✗	✓	✓
Subir archivos	✓	✓	✓
Solicitar eliminación	✓	✓	✓
Aprobar/rechazar eliminación	✗	✓	✓
Ver audit log completo	✗	✓	✓
Gestionar entidades	✗	✗	✓
Acceder a MinIO / Storage backend	✗	✗	✓
Exportar reportes de auditoría	✗	✓	✓

SECCIÓN 6

Estrategia de Hosting y Fases de Implementación

Fase 1 — Cloud (Inmediata)

Frontend	Next.js en Vercel — deploy automático desde Git
Backend / BD	Supabase Cloud Pro (~\$25 USD/mes) — PostgreSQL + Auth + Storage
CDN / SSL	Cloudflare Free — DNS, proxy, certificados automáticos
Dominio	Nameservers del dominio existente apuntando a Cloudflare

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

Subdominio	portal.dominio.com → Vercel api.dominio.com → Supabase
Costo estimado	\$25–45 USD/mes total
Object Lock	Soft lock lógico mediante RLS — sin WORM físico hasta Fase 2

Fase 2 — Self-hosted / NAS (3–6 meses)

Almacenamiento	MinIO en NAS (Synology DS423+ o DS923+) con Object Lock WORM habilitado
Servidor	Dell PowerEdge R350 con Proxmox para Tactical RMM y servicios adicionales
BD	Posible migración a Supabase self-hosted (Docker) en el servidor Proxmox
Conectividad	Cloudflare Tunnel para exponer servicios sin abrir puertos directamente
Backup	Regla 3-2-1: producción + réplica NAS + backup cloud (Backblaze B2)
Object Lock	MinIO Governance Mode — admin puede liberar con log; Compliance Mode en revisión

Nota de abstracción: Desde el día uno el acceso a storage se encapsula en un servicio único (storage.service.ts) con métodos uploadFile(), getFileUrl() y deleteFile(). La migración de Supabase Storage a MinIO en Fase 2 solo requiere cambiar la implementación de este servicio, sin modificar el resto del sistema.

SECCIÓN 7

Seguridad y Cumplimiento ISO/IEC 27001:2022

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

Control ISO 27001	Implementación en el sistema
A.5.9 — Inventario de activos	Tabla archivos con metadatos completos, hash y propietario por entidad
A.5.15 — Control de acceso	Supabase Auth + RLS en todas las tablas por entidad_id
A.5.31 — Requisitos legales	Flujo de autorización documentado y trazable para cualquier eliminación
A.5.32 — Derechos de propiedad intelectual	Aislamiento por entidad — ningún cliente accede a documentos de otro
A.8.10 — Eliminación de información	Object Lock WORM (Fase 2) — eliminación solo con autorización formal en log
A.8.11 — Enmascaramiento de datos	IPs en audit_log parcialmente enmascaradas (187.x.x.x)
A.8.15 — Registro de eventos	audit_log append-only con actor, acción, recurso, IP y timestamp
A.8.16 — Monitoreo de actividades	Dashboard admin con alertas de solicitudes pendientes en tiempo real

Transmisión y cifrado

En tránsito	TLS 1.3 en todas las conexiones cliente ↔ servidor (Cloudflare + Vercel)
En reposo	AES-256 en Supabase Storage. MinIO soporta SSE-S3 y SSE-KMS en Fase 2
Autenticación	JWT firmados por Supabase Auth con expiración configurable
Hash archivo	SHA-256 calculado en cliente y verificado en servidor al momento de la subida

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

SECCIÓN 8

Glosario de Términos

Término	Definición
RLS (Row Level Security)	Mecanismo de PostgreSQL que aplica políticas de acceso a nivel de fila, independiente de la capa de aplicación
Object Lock / WORM	Write Once Read Many — mecanismo de almacenamiento que impide la modificación o eliminación de objetos durante un período definido
JWT (JSON Web Token)	Token firmado digitalmente que contiene la identidad y permisos del usuario autenticado
SHA-256	Función hash criptográfica que genera un identificador único de 256 bits para verificar la integridad de un archivo
Audit Log	Registro cronológico e inmutable de todas las acciones realizadas sobre los recursos del sistema
Cloudflare Tunnel	Servicio que permite exponer servicios internos a internet sin abrir puertos en el firewall
MinIO	Servidor de almacenamiento de objetos compatible con Amazon S3, ejecutable en infraestructura propia
Governance Mode	Modo de Object Lock que permite a super administradores liberar el bloqueo, dejando trazabilidad completa en el log

CONTROL-DICAMX

Documentación de Arquitectura del Sistema

Versión 1.0 | June 2026

ISO 27001

Audit Log

WORM Ready

Multi-entidad

Elaborado por:
Rodrigo Fuentes Espinoza
Coordinador de Sistemas
DICA México / TKS México

Fecha de emisión:
02 de June de 2026

Versión: 1.0